

PyPi-AI Evidence Report

Static-only scanner; never executes untrusted package code.

Developers

VASANTH ADITHYA - 160123749049 - vasanthfeb13@gmail.com

SAI GEETHIKA - 160123749302 - yedlasaigeethika37@gmail.com

Summary

Target: examples/safe_packages/env_network

Risk: 45/100 (medium)

Findings: 3

Evidence

ID	Rule	Severity	Location
F001	PY001_ENV_ACCESS	medium	env_network_demo/__init__.py:7
F002	PY001_ENV_ACCESS	medium	env_network_demo/__init__.py:12
F003	PY003_NETWORK_CLIENT	medium	env_network_demo/__init__.py:13

Citations

CHASE: Toda, T. and Mori, T. CHASE: LLM Agents for Dissecting Malicious PyPI Packages. 2025 IEEE/ACM Alware.

PYPA_SDIST: PyPA source distribution format specification.

PYPA_WHEEL: PyPA binary distribution wheel format specification.

PYTHON_TARFILE: Python tarfile extraction filters documentation.

GEMINI: Google Gemini API structured output documentation.

OLLAMA: Ollama API and cloud documentation.

OSV: OSV.dev public vulnerability database and API for open-source packages.

MALWARE_EXAMPLES: Public reports and datasets from Datadog, Unit42, Fortinet, and ReversingLabs for package-name examples only.